

FeDril UAT: No-CUI Readiness Workflow

Status basis: Implemented UI tabs and API behavior were checked against `apps/web/src/App.tsx`, `apps/api/Program.cs`, and focused API tests for company profiles, contracts, contract deliverables, clauses, obligations, evidence metadata, CMMC readiness, POA&M records, reports, audit logs, tenant isolation, and RBAC.

Do not use real customer CUI, classified information, export-controlled technical data, credentials, payroll records, private keys, or production customer evidence in this UAT.

Acceptance Categories

Category	UAT Coverage	Current-State Label
Company profile	UAT-P01 through UAT-P04	Implemented
One configured No-CUI readiness workflow that shows contract metadata	UAT-01 through UAT-04	Implemented
Contract deliverables	UAT-D01 through UAT-D04	Implemented
Attached or reviewed clauses	UAT-05 through UAT-06	Implemented
Generated obligations	UAT-07	Implemented
Owner/status tracking	UAT-08 through UAT-09	Implemented
Allowed evidence metadata	UAT-10 through UAT-12	Implemented
CMMC readiness module	UAT-C01 through UAT-C04	Implemented
A current report artifact	UAT-13	Implemented
Audit history	UAT-14 through UAT-15	Implemented

Roles

Role	UAT Actor	Use In This Test	Permission Expectation
Owner	Morgan Lane, morgan.lane+uat@example.com	Tenant setup, No-CUI mode, audit review	Can manage the profile, contracts, deliverables, tenant settings, and audit review
Admin	Jordan Miles, jordan.miles+uat@example.com	User setup and operational fallback	Can manage the profile, contracts, deliverables, users, and workflow records, but not tenant ownership
Compliance Manager	Priya Shah, priya.shah+uat@example.com	Profile, contract, deliverable, clause, obligation, evidence, reports	Can manage the core compliance workflow, including the profile and contract deliverables
Contributor	Devin Brooks, devin.brooks+uat@example.com	Evidence metadata and assigned work	Can view the profile, contracts, and deliverables; can manage evidence and tasks; cannot modify profile or contract deliverables
Auditor	Elena Carter, elena.carter+uat@example.com	Read-only acceptance review	Can view the profile, contracts, deliverables, and reports; cannot modify workflow data or audit logs
Advisor	Avery Quinn, avery.quinn+advisor@example.com	External compliance advisor review	Can view but not modify the profile; can manage contracts and deliverables and view audit history inside the tenant boundary

Note: In local development, the React app uses development authentication headers. Treat the names above as test personas unless separate login accounts are configured. Switch user lists only active users with an active membership in the selected tenant. Before UAT-09, confirm Priya Shah and Devin Brooks have active memberships; an invitation that has not been accepted

is not sufficient.

Test Data

Data Type	Field	Value
Tenant	Active tenant	GCCS Development Tenant
Tenant mode	Data handling mode	NoCui
Profile	Legal entity	Blue Ridge Federal Support LLC
Profile	DBA	Blue Ridge Support
Profile	UEI	UAT123ABC456
Profile	CAGE	7UAT1
Profile	SAM expires	2027-07-31
Profile	Primary NAICS	541512 - Computer Systems Design Services
Profile	NAICS size basis	UAT synthetic value - not an SBA determination
Profile	NAICS status	Small for this synthetic fixture only
Profile	Agency customers	DHS synthetic UAT customer
Profile	Contractor role	Subcontractor
Profile	Products and services	Synthetic non-CUI help desk and compliance support services.
Profile	Employees	Small
Profile	Revenue	Small
Profile	Location	UAT Headquarters
Profile	Address	100 Test Plaza, Arlington, VA, 22201, USA
Profile	IT summary	Synthetic Microsoft 365 and managed endpoint environment used only for No-CUI UAT.
Profile	FCI/CUI posture	FCI only
Profile	Key systems	Microsoft 365, synthetic help desk
Contract	Contract number	DEMO-NC-26-0007
Contract	Title	Non-CUI Help Desk Support BPA Call
Contract	Agency or prime	Fictional Prime Systems Inc. for DHS
Contract	Role	Subcontractor
Contract	Contract type	Fixed price
Contract	Status	Active
Contract	Awarded	2026-06-15
Contract	Start	2026-07-01
Contract	End	2027-06-30
Contract	FCI/CUI posture	FCI only
Contract	Place of performance	Virginia, remote support
Contract	Description	Synthetic No-CUI contract for UAT. FCI-only support workflow, no customer CUI, no classified data, no export-controlled technical data.
Deliverable	Name	Monthly service status report - synthetic
Deliverable	Owner	Contracts
Deliverable	Due date	2026-08-31

Data Type	Field	Value
Deliverable	Initial status	Not started
Deliverable	Description	Synthetic monthly performance summary containing no customer CUI or sensitive government data.
Deliverable negative test	Name	Overdue corrective-action summary - synthetic
Deliverable negative test	Owner	Compliance
Deliverable negative test	Due date	2026-07-15
Deliverable negative test	Status	In progress
Document	File name	demo-nc-contract.txt
Document	Content	Synthetic No-CUI contract fixture for UAT. Includes FAR 52.204-21, FAR 52.204-25, and FAR 52.204-27 references. No customer CUI, classified information, export-controlled technical data, credentials, payroll, or secrets.
Clause	Search terms	52.204-21, 52.204-25, 52.204-27
Evidence	Title	MFA configuration summary - synthetic
Evidence	Type	System configuration
Evidence	Owner	Security
Evidence	Status	Approved
Evidence	Effective	2026-06-01
Evidence	Expires	2027-01-31
Evidence	Tags	FAR 52.204-21, FCI, MFA, UAT
Evidence	Controls	AC.L1-3.1.1
Evidence	Classification	FCI
Evidence	Classification reason	User confirmed synthetic FCI-only evidence for No-CUI UAT.
Report	Package title	Prime review evidence package - No-CUI UAT
CMMC	Assessment name	No-CUI Level 1 readiness workspace
CMMC	Target level	Level 1
CMMC	Framework	FAR basic safeguarding
CMMC	Status	In progress
CMMC	Started	2026-06-15
CMMC	Affirmation due	2027-06-15
CMMC	Owner	Security
CMMC	Control for readiness review	AC.L1-3.1.1
CMMC POA&M	Control	AC.L1-3.1.1
CMMC POA&M	Risk	High
CMMC POA&M	Status	Open
CMMC POA&M	Owner	Security
CMMC POA&M	Due date	2026-07-15
CMMC POA&M	Gap	Synthetic UAT gap: document annual access review evidence.
CMMC POA&M	Remediation plan	Upload synthetic access review summary and link it to the control.

Pre-Publication Checklist

Before using this UAT as a sales, demo, or customer-facing asset, confirm:

Check	Required Evidence
Does the UI expose this flow?	Dashboard, Profile, Settings, Contracts, Calendar, Obligations, Evidence, CMMC, and Reports tabs are visible for the role under test
Does the API enforce this rule?	Endpoint returns expected success, 403, 404, or validation error
Is there a test proving it?	Relevant API test exists for the behavior
Does wording avoid overclaims?	No claim of certification, official compliance status, legal advice, government approval, guaranteed security, or audit-ready status
Does it preserve No-CUI posture?	Test data is synthetic and NoCui mode rejects CUI handling

UAT-01: Confirm No-CUI Mode

Category: One configured No-CUI readiness workflow that shows contract metadata.

Role: Owner.

Tab: Settings.

Steps:

1. Open the FeDril app in local development.
2. Click the Settings tab.
3. Find Data handling mode.
4. Confirm the displayed mode is NoCui.
5. If the form is editable, enter NoCui for Mode.
6. Enter UAT reset to No-CUI compliance management mode. for Reason for mode change.
7. Leave Approval checklist ID blank.
8. Click Update mode.
9. Confirm Tenant data handling mode history shows a row with New = NoCui.

Expected result: The tenant is configured for No-CUI compliance management only.

Reason: This establishes the safety boundary for every later step. If the tenant is not in NoCui, evidence, reporting, and contract-document expectations may not match the MVP posture.

UAT-02: Verify Role Access Surface

Category: One configured No-CUI readiness workflow that shows contract metadata.

Role: Owner or Admin.

Tab: Settings.

Steps:

1. Stay on **Settings**.
2. Review the visible role guidance or current access details if shown.
3. Confirm the test actor can access **Contracts**, **Obligations**, **Evidence**, and **Reports**.
4. Sign in as **Auditor**, open **Reports**, click an existing report card, and confirm the full report detail is brought into view and can be read.
5. Confirm a direct tenant-scoped GET `/api/reports/{reportId}` for that same report returns 200, while a cross-tenant request returns 404.
6. Confirm all report-generation and archive controls are absent for **Auditor**, and that direct POST attempts to every report-generation endpoint and `/api/reports/{reportId}/archive` return 403 without changing the report, creating an audit event for the report, or causing another side effect.
7. Confirm **Contributor** can help with evidence and task work but cannot generate reports or approve evidence.

Expected result: UAT actors are assigned to roles that match the work they perform.

Reason: A UAT result is not meaningful if the actor has excessive privileges. This step separates operator behavior from reviewer behavior.

UAT-02A: Verify MVP Access-Control Enforcement

Category: Authorized users and authorized transactions/functions.

Role: Owner or Admin for setup; Auditor and Compliance Manager for role checks.

Tabs: **CMMC**, **Reports**, and **Settings**.

Current-state label: Implemented for tenant-scoped API permission gates; partially implemented as UI affordances.

Implementation evidence: Protected API routes require authentication, active tenant context, and endpoint permissions such as **ViewCmmc**, **ManageCmmc**, **ViewReports**, and **ManageReports**. Tenant membership authorization is enforced outside local development. Local development uses explicit development authentication headers and should not be treated as production identity proof.

Steps:

1. Sign in or switch local development context to **Auditor**.
2. Click the **CMMC** tab.
3. Confirm **CMMC** readiness data can be viewed.
4. Confirm create/update controls such as **Create assessment**, **Save assessment**, **Create POA&M**, or equivalent mutation controls are unavailable or disabled for **Auditor**.
5. Click the **Reports** tab.
6. Confirm existing report cards can be opened and read.
7. Confirm report generation and archive controls are unavailable or disabled for **Auditor**.

8. If an authorized API harness is available, call GET /api/me/access as the Auditor and inspect the top-level permissions array for the active user. Confirm that permissions includes ViewCmmc and ViewReports, but does not include ManageCmmc or ManageReports.

- Do not use rolePermissionMatrix for this pass/fail check. That matrix lists permissions for every role in the system, so it can contain ManageCmmc and ManageReports even when the active Auditor does not have those permissions.
- Expected Auditor pass condition: the response may include rolePermissionMatrix.Owner, rolePermissionMatrix.Admin, rolePermissionMatrix.Compliance Manager, or rolePermissionMatrix.Advisor entries with management permissions, but the top-level permissions array for the active Auditor must not contain ManageCmmc or ManageReports.
- If ManageCmmc or ManageReports appears in the top-level permissions array, the request is not using a clean Auditor context. Confirm roles contains only Auditor, remove any X-Gccs-Dev-Permissions header from Postman, and confirm the local development selector is set to Auditor.

9. If an authorized API harness is available, attempt:

- POST /api/cmmc/assessments.
- PATCH /api/cmmc/assessments/{assessmentId}/controls/{controlId}.
- POST /api/reports/cmmc-readiness?assessmentId={assessmentId}.

10. Confirm each unauthorized mutation returns 403 and does not create, update, archive, or generate records.

11. Switch local development context to Compliance Manager or Owner.

12. Confirm the same CMMC/report actions are available when the role has the required permissions.

13. If an authorized API harness is available, repeat GET /api/me/access and confirm the response includes the permissions required for the action under test.

14. If tenant A and tenant B test contexts are available, attempt to access a tenant B resource while sending tenant A context.

15. Confirm the cross-tenant request returns 403 or 404 and does not disclose tenant B data.

16. Return to Settings, find Audit log, and confirm successful allowed mutations create audit events. Do not expect audit events for every rejected authorization attempt unless the endpoint explicitly records them.

Expected result: Signed-in users can access only tenant records and application functions authorized by their active tenant role. Direct API calls are rejected when the role lacks the required permission.

Reason: This verifies the MVP implementation of "authorized users" and "authorized transactions/functions" without claiming full CMMC certification or complete customer control satisfaction.

Profile Module UAT

Current-state label: Implemented.

Implementation evidence: The Profile tab calls tenant-scoped GET /api/company-profile and PUT /api/company-profile. The API requires ViewCompanyProfile to read and ManageCompanyProfile to save. Focused tests cover draft persistence, completion validation, completion percentage, tenant isolation, and audit history.

UAT-P01: Save An Incomplete Company Profile Draft

Category: Company profile.

Role: Compliance Manager.

Tab: Profile.

Steps:

1. Click the Profile tab in the left navigation.
2. Confirm the page heading is Create company profile if no profile exists, or shows the current legal entity name if a profile already exists.
3. If an existing profile contains production or customer data, stop and use a dedicated UAT tenant. Do not overwrite customer data.
4. Enter Blue Ridge Federal Support LLC in Legal entity.
5. Leave UEI, CAGE, and SAM expires blank for this negative validation step.
6. Click Save draft.
7. Confirm the status message is Draft saved..
8. Confirm the completion meter shows Draft and a value below 100%.
9. Reload the browser.
10. Return to the Profile tab.
11. Confirm Blue Ridge Federal Support LLC remains in Legal entity and the profile still shows Draft.

Expected result: The incomplete profile persists as a draft and is not represented as complete.

Reason: Users need to preserve partial onboarding work without bypassing the server-side fields required for profile completion.

UAT-P02: Verify Completion Validation

Category: Company profile.

Role: Compliance Manager.

Tab: Profile.

Steps:

1. Stay on Profile with the incomplete draft from UAT-P01.
2. Click Complete profile without entering the missing required values.
3. Confirm an error summary appears instead of a success message.
4. Confirm the summary identifies missing completion data, including uei, cageCode, and samRegistrationExpiresAt.
5. Confirm the completion meter remains Draft and below 100%.
6. Reload the page and confirm the attempted completion did not mark the record complete.

Expected result: The API rejects completion while required profile fields are missing, and the stored profile remains a draft.

Reason: This distinguishes server-enforced completion requirements from a visual progress indicator. A button click alone must not convert incomplete data into a completed profile.

UAT-P03: Complete The Synthetic Company Profile

Category: Company profile.

Role: Compliance Manager.

Tab: Profile.

Steps:

1. Stay on Profile.
2. Enter the Profile values from the Test Data table:
 - Legal entity: Blue Ridge Federal Support LLC.
 - DBA: Blue Ridge Support.
 - UEI: UAT123ABC456.
 - CAGE: 7UAT1.
 - SAM expires: 2027-07-31.
 - Role: Subcontractor.
 - Agency customers: DHS synthetic UAT customer.
 - Products and services: Synthetic non-CUI help desk and compliance support services..
 - Employees: Small.
 - Revenue: Small.
3. In NAICS codes, keep one row and select its Primary radio button.
4. Enter 541512 for Code and Computer Systems Design Services for Title.
5. Enter UAT synthetic value - not an SBA determination for Size basis.
6. Choose Small for the synthetic Status. Do not use this selection as an actual SBA size determination.
7. Enter the location values:
 - Location: UAT Headquarters.
 - Street: 100 Test Plaza.
 - City: Arlington.
 - State: VA.
 - Postal code: 22201.
 - Country: USA.
8. Enter Synthetic Microsoft 365 and managed endpoint environment used only for No-CUI UAT. in IT summary.
9. Choose FCI only for FCI/CUI posture.
10. Enter Microsoft 365, synthetic help desk in Key systems.
11. Leave Uses external service provider unchecked unless the UAT scenario specifically requires one.
12. Click Complete profile.
13. Confirm the status message is Profile complete..
14. Confirm the completion meter shows Complete and 100%.

15. Reload the page and confirm the completed values persist.

Expected result: The synthetic company profile is saved as complete and displays 100% after all server-required fields are present.

Reason: Company profile facts provide tenant business context for applicability, contracts, renewals, readiness work, and reports. The synthetic size-status values are test inputs, not legal or SBA determinations.

UAT-P04: Verify Profile Read-Only Access And Tenant Isolation

Category: Company profile.

Roles: Contributor, Auditor, Advisor, and Compliance Manager.

Tab: Profile.

Steps:

1. Switch to the Contributor persona and apply the context.
2. Click Profile and confirm the completed synthetic profile is visible.
3. Confirm the profile fields and Save draft and Complete profile actions are disabled.
4. Repeat steps 1 through 3 as Auditor and Advisor.
5. Attempt a direct PUT /api/company-profile as each read-only profile role and confirm the response is 403.
6. Reload the profile and confirm none of the denied requests changed any value or created a profile update audit event.
7. Using an authorized test harness, request GET /api/company-profile under a different tenant context that has no profile.
8. Confirm the response is 204 with no profile body; it must not return Blue Ridge Federal Support LLC or its identifiers.
9. Switch back to the Compliance Manager persona before continuing.

Expected result: Contributor, Auditor, and Advisor can view the selected tenant's profile but cannot modify it. A different tenant receives only its own profile or an empty response.

Reason: The UI must reflect server-authoritative permissions, but the acceptance boundary is the API denial and unchanged persisted state. Tenant isolation prevents business identity and registration metadata from leaking across workspaces.

UAT-03: Create The No-CUI Contract Record

Category: One configured No-CUI readiness workflow that shows contract metadata.

Role: Compliance Manager.

Tab: Contracts.

Steps:

1. Click the Contracts tab.
2. Click New contract if an existing contract is selected.

3. In `Create contract record`, enter the contract data from the `Test Data` section.
4. Confirm `FCI/CUI posture` is `FCI only`.
5. Click `Create contract`.
6. Select `DEM0-NC-26-0007` in `Contract records`.

Expected result: The selected contract displays its number, title, agency or prime, relationship, type, status, dates, posture, place of performance, and description.

Reason: Contract metadata is the anchor for clause attachment, obligation generation, evidence scope, reporting scope, and audit history.

UAT-04: Upload Contract Document Metadata

Category: One configured No-CUI readiness workflow that shows contract metadata.

Role: Compliance Manager.

Tab: `Contracts`.

Steps:

1. Stay on `Contracts`.
2. Select `DEM0-NC-26-0007`.
3. In `Required before contract or evidence work`, confirm the current No-CUI notice is acknowledged. If it is not, check all four `Required user acknowledgement` statements and click `I acknowledge the No-CUI upload limitation`.
4. Confirm the acknowledgement status is `Acknowledged` before continuing.
5. In `Documents`, set `Document type` to `Contract`.
6. Set `Contract document classification` to `FCI`.
7. Choose a local text file named `demo-nc-contract.txt` containing the allowed synthetic text from `Test Data`.
8. Check `I confirm this file does not contain CUI, classified information, export-controlled data, ITAR data, or sensitive government-furnished information`.
9. Click `Upload document`.
10. Confirm the document appears in the document list with `FCI` classification, `accepted validation`, and `clean malware status`.
11. Click `Start extraction`.
12. Confirm the status progresses from `Queued` or `Processing` to `Completed` and that the candidate count is displayed.

Expected result: The app accepts the synthetic FCI-only text document, stores it privately after malware scanning, and completes tenant-scoped clause extraction.

Reason: This proves the workflow can process an allowed synthetic contract document without accepting prohibited CUI content or treating extracted candidates as reviewed clauses.

Contract Deliverables UAT

Current-state label: Implemented.

Implementation evidence: Deliverables are displayed inside the selected contract on the Contracts tab. Tenant-scoped list, create, and update endpoints require ViewContracts or ManageContracts. Focused tests cover contract-detail display, calendar-task creation, overdue calculation, and deliverable audit events.

UAT-D01: Create A Contract Deliverable

Category: Contract deliverables.

Role: Compliance Manager.

Tab: Contracts.

Prerequisite: UAT-03 is complete and contract DEMO-NC-26-0007 is selected.

Steps:

1. Click the Contracts tab.
2. Select contract DEMO-NC-26-0007 from Contract records.
3. Scroll within the contract detail until the Deliverables section is visible. This section is below Attached clauses and above Documents in the current UI.
4. Enter Monthly service status report - synthetic in Name.
5. Enter Contracts in Owner.
6. Enter 2026-08-31 in Due date.
7. Choose Not started in Deliverable status.
8. Enter Synthetic monthly performance summary containing no customer CUI or sensitive government data. in Deliverable description.
9. Click Add deliverable.
10. Confirm the message is Deliverable added to the contract calendar..
11. Confirm the deliverable list shows its name, owner, due date, description, and Not started status.
12. Reload the page, reselect DEMO-NC-26-0007, return to Deliverables, and confirm the record persists.

Expected result: The deliverable is created under the selected contract and remains visible after reload.

Reason: A contract deliverable must retain its contract association, owner function, due date, description, and lifecycle state. Persistence after reload distinguishes a saved record from temporary UI state.

UAT-D02: Verify Deliverable Calendar Linkage

Category: Contract deliverables.

Role: Compliance Manager or Contributor.

Tab: Calendar.

Steps:

1. Click the Calendar tab.
2. Set the calendar date range so that it includes 2026-08-31.
3. Apply a source or module filter for contract deliverables if that filter is available; otherwise review the complete date range.
4. Find Monthly service status report - synthetic.
5. Confirm its date is 2026-08-31 and its owner is Contracts when displayed.
6. Return to Contracts, select DEMO-NC-26-0007, and confirm the source deliverable still shows the same due date and owner.

Expected result: The dated deliverable appears in the tenant-scoped calendar without requiring duplicate manual task entry.

Reason: Calendar linkage turns contract performance dates into visible operational work. The API creates or synchronizes a calendar task when the deliverable is saved.

UAT-D03: Verify Overdue State And Status Update

Category: Contract deliverables.

Role: Compliance Manager.

Tab: Contracts, then Calendar.

Steps:

1. On Contracts, select DEMO-NC-26-0007 and return to Deliverables.
2. Create a second deliverable using the negative-test values from Test Data:
 - Name: Overdue corrective-action summary - synthetic.
 - Owner: Compliance.
 - Due date: 2026-07-15.
 - Deliverable status: In progress.
 - Deliverable description: Synthetic past-due record used to verify overdue presentation..
3. Click Add deliverable.
4. Confirm the new row displays both In progress and Overdue.
5. In the status selector for Monthly service status report - synthetic, choose Submitted.
6. Confirm the message is Deliverable updated. and the row displays Submitted.
7. Reload the page and confirm Submitted persists.
8. Click Calendar, include both deliverable dates in the date range, and confirm both records are visible.

Expected result: A past-due incomplete deliverable is flagged overdue, and an authorized status update persists and synchronizes with the calendar task.

Reason: Overdue state is derived from due date and incomplete status, while lifecycle status is an explicit user-controlled value. Testing both catches date-calculation and persistence failures.

UAT-D04: Verify Deliverable Read-Only Access And Tenant Isolation

Category: Contract deliverables.

Roles: Contributor, Auditor, Advisor, and Compliance Manager.

Tab: Contracts.

Steps:

1. Switch to the Contributor persona and apply the context.
2. Click Contracts, select DEMO-NC-26-0007, and scroll to Deliverables.
3. Confirm existing deliverables are visible but the create form and status selectors are disabled.
4. Repeat steps 1 through 3 as Auditor.
5. Attempt direct POST `/api/contracts/{contractId}/deliverables` and PUT `/api/contracts/{contractId}/deliverables/{deliverableId}` requests as Contributor and Auditor.
6. Confirm each mutation returns 403, existing deliverable values remain unchanged, no additional calendar task is created, and no deliverable audit event is written.
7. Switch to Advisor and confirm the create form and status selector are enabled because Advisor currently has ManageContracts.
8. Do not create another record as Advisor unless that role behavior is specifically under test.
9. Using an authorized test harness with a different tenant context, request GET `/api/contracts/{contractId}/deliverables` using the original tenant's contract ID.
10. Confirm the response is 404 and does not disclose deliverable names, dates, owners, or IDs.
11. Switch back to the Compliance Manager persona before continuing.

Expected result: Contributor and Auditor can view but cannot mutate deliverables. Advisor can manage deliverables under the current permission catalog. Cross-tenant access returns 404 without record disclosure.

Reason: Deliverables inherit contract authorization. Testing UI state alone is insufficient; direct API denial, unchanged tasks and audit history, and cross-tenant non-disclosure prove the boundary.

UAT-05: Search Source-Backed Clauses

Category: Attached or reviewed clauses.

Role: Compliance Manager or Advisor.

Tab: Obligations.

Steps:

1. Click the Obligations tab.
2. Find Clause library search.

3. Search 52 . 204 - 21.
4. Record the published clause ID for the matching FAR clause.
5. Repeat for 52 . 204 - 25.
6. Repeat for 52 . 204 - 27.
7. Confirm each result includes clause number, title, source URL, confidence or review state when displayed.

Expected result: Published clause records can be located before attachment.

Reason: Clause-driven obligations should come from reviewed source-backed content, not free-form user text.

UAT-06: Attach Clauses To Contract

Category: Attached or reviewed clauses.

Role: Compliance Manager.

Tab: Contracts.

Steps:

1. Click the Contracts tab.
2. Select DEMO-NC-26-0007.
3. In Attached clauses, paste the published clause ID for 52 . 204 - 21.
4. Enter Manual UAT tagging from synthetic contract text. for Attachment reason.
5. Enter demo-nc-contract.txt for Source document reference.
6. Click Attach clause.
7. Repeat steps 3 through 6 for 52 . 204 - 25 and 52 . 204 - 27.
8. Confirm attached rows show clause number, title, source URL, and review metadata when available.

Expected result: Three clauses are attached to the contract.

Reason: Attachment creates the bridge from contract metadata to source-backed obligation generation.

UAT-07: Generate And Review Contract Obligations

Category: Generated obligations.

Role: Compliance Manager.

Tab: Contracts, then Obligations.

Steps:

1. Stay on Contracts.

2. In the attached clause row for 52.204-21, use the available generate action if visible.
3. If generation occurs automatically after attachment, proceed to the next step.
4. Click the Obligations tab.
5. In Obligation work queue, filter by contract DEMO-NC-26-0007.
6. Apply any useful filters: Risk = High, Owner = Security or IT/security, Module = Cybersecurity, Source = 52.204-21.
7. Open the matching obligation with View details.
8. Confirm detail sections include Why it applies, Required action, Owner, Source, Confidence, Last reviewed, Evidence examples, and Flow-down.

Expected result: At least one source-backed obligation appears for the contract, preserving clause and source metadata.

Reason: The acceptance point is not merely that a clause is attached. The system should turn reviewed clause mappings into actionable work while preserving provenance.

UAT-08: Update Obligation Status

Category: Owner/status tracking.

Role: Compliance Manager.

Tab: Obligations.

Steps:

1. Stay in the opened obligation detail.
2. In Update status, choose In progress.
3. Click Save status.
4. Confirm the status shown in detail or the work queue changes to In progress.

Expected result: The obligation status updates for the selected tenant-scoped contract obligation.

Reason: Status tracking is the operational control that turns static compliance content into an active readiness workflow.

UAT-09: Assign Obligation Owner

Category: Owner/status tracking.

Role: Compliance Manager.

Tab: Obligations.

Prerequisite: Priya Shah and Devin Brooks are active members of the selected tenant. Confirm both names appear under Switch user before assigning the obligation. If the selector is disabled or either name is absent, complete the tenant invitation/activation workflow first.

Steps:

1. Stay in the opened obligation detail.
2. In **Assign by**, choose **Tenant member**.
3. In **Tenant member**, choose **Devin Brooks**.
4. Leave **Also send assignment email** checked.
5. Click **Assign owner**.
6. Reload, reopen the obligation detail, and confirm **Currently assigned to**, **Assign by**, and **Tenant member** show **Devin Brooks**.
7. In the local test context, use **Switch user** to select **Devin Brooks** and apply the context.
8. Confirm the notification bell shows an unread direct assignment. Open it, then return to **Obligations** and select **My assignments**.
9. Switch the development user back to **Priya Shah**, assign the same obligation by **Role**, and choose **Compliance manager**.
10. Reload, reopen the detail, and confirm the saved role remains displayed.
11. Select **Role assignments** and confirm the obligation appears with the role-queue count.
12. Switch to an active **Compliance Manager** persona and confirm the bell contains the role-assignment notification.

Expected result: A tenant-member or role assignment remains visible after reload in both the persistent assignment summary and assignment controls. A directly assigned member receives an in-app notification and can find the obligation under **My assignments**. Active members of an assigned role receive one deduplicated in-app notification and can find the obligation under **Role assignments**. When direct-assignment email delivery is configured and the member's **Assignment emails** preference is enabled, an email is queued asynchronously. Role-assignment email remains disabled.

Reason: Direct and role ownership must survive reload, provide an explicit queue, and make eligible recipients aware of new work. Role notification fan-out remains tenant-scoped and in-app only to avoid ungoverned mass email. Asynchronous direct-assignment email delivery prevents an external email-provider failure from rolling back the obligation assignment.

UAT-10: Acknowledge No-CUI Evidence Rules

Category: Allowed evidence metadata.

Role: Contributor or Compliance Manager.

Tab: Evidence.

Steps:

1. Click the **Evidence** tab.
2. Find **No-CUI acknowledgement**.
3. Read the notice and confirm it prohibits real customer CUI in No-CUI mode.
4. Click **I acknowledge the No-CUI upload limitation**.
5. Confirm the status changes to **Acknowledged**.

Expected result: Evidence controls become available only after acknowledgement.

Reason: The acknowledgement is an operational safety gate. It educates users before they create or upload evidence in a No-CUI tenant.

UAT-11: Create Allowed Evidence Metadata

Category: Allowed evidence metadata.

Role: Contributor or Compliance Manager.

Tab: Evidence.

Steps:

1. Stay on Evidence.
2. Find Evidence metadata.
3. Click New evidence.
4. Enter the evidence data from the Test Data section.
5. For Obligations, paste the generated FAR 52.204-21 obligation ID if visible; otherwise leave blank and rely on the Controls link.
6. For Controls, enter AC.L1-3.1.1.
7. Click Create metadata.
8. Confirm the record appears in Evidence list.

Expected result: The evidence record appears with title, type, owner, status, dates, tags, classification, and control or obligation links.

Reason: Evidence metadata lets the system track proof without requiring storage of sensitive file content.

UAT-12: Negative Evidence Classification Check

Category: Allowed evidence metadata.

Role: Compliance Manager.

Tab: Evidence.

Steps:

1. Stay on Evidence.
2. Select the synthetic evidence item or create a new test evidence record.
3. Attempt to classify it as CUI while the tenant remains in NoCui mode.
4. Enter Negative UAT check: NoCui mode should not accept CUI evidence. as the classification reason.
5. Submit the classification change.

Expected result: The workflow is rejected or blocked by the No-CUI policy.

Reason: A positive-only UAT misses the main safety guarantee. This negative test proves that No-CUI mode does not silently accept CUI-labeled evidence.

CMMC Module UAT

Current-state label: Implemented.

Implementation evidence: The CMMC tab exposes CMMC and NIST workspace, Readiness assessments, Control readiness, and POA&M remediation. The API exposes tenant-scoped CMMC assessment, control, POA&M, affirmation, and readiness report routes under `/api/cmmc/...` and `/api/reports/cmmc-readiness`. Focused tests cover Level 1 and Level 2 assessment creation, control baseline loading, control status updates, evidence/task/asset/POA&M links, traceability validation, POA&M calendar linkage, affirmation calendar/reminder behavior, CMMC readiness report language, RBAC, and tenant isolation.

Important posture limit: This module tracks CMMC readiness work only. It does not certify CMMC compliance, provide an assessor determination, authorize real CUI storage, or replace qualified CMMC/security review.

UAT-C01: Create A No-CUI CMMC Readiness Assessment

Category: CMMC readiness module.

Role: Compliance Manager.

Tab: CMMC.

Steps:

1. Click the CMMC tab under the Assurance navigation group.
2. Confirm the page heading is CMMC and NIST workspace.
3. Confirm the MVP posture banner says the current tenant is NoCui and that real CUI, classified, and export-controlled data are blocked.
4. In the assessment form, enter the CMMC values from the Test Data section:
 - Assessment name: No-CUI Level 1 readiness workspace.
 - Target level: Level 1.
 - Framework: FAR basic safeguarding.
 - Status: In progress.
 - Started: 2026-06-15.
 - Affirmation due: 2027-06-15.
 - Owner: Security.
 - Contract link: DEMO-NC-26-0007, if that contract appears in the selector; otherwise leave No contract selected.
5. Click Create assessment.
6. Confirm the assessment appears under Readiness assessments.
7. Confirm the assessment card shows:

- Level 1.
- In Progress.
- Owner: Security.
- Affirmation due: 2027-06-15.
- Complete: a percentage value.
- Implemented: implemented count over total control count.
- Open POA&M: a count.

Expected result: A Level 1 CMMC readiness assessment is created and displayed with owner, dates, progress summary, and POA&M summary.

Reason: This verifies the CMMC module is part of the No-CUI readiness workflow without claiming CMMC certification or CUI-ready operation.

UAT-C02: Review The CMMC Control Readiness Baseline

Category: CMMC readiness module.

Role: Compliance Manager or Auditor.

Tab: CMMC.

Prerequisite: UAT-C01 is complete and at least one CMMC readiness assessment is listed.

Steps:

1. Stay on the CMMC tab.
2. Find Control readiness.
3. Locate control AC.L1-3.1.1 or another visible Level 1 control.
4. Confirm each visible control card includes:
 - Control ID and title.
 - Status, such as Not Started, Implemented, Partially Implemented, Not Applicable, or Needs Review.
 - Assessment result, such as Not Assessed, Met, or Not Met.
 - Source confidence.
 - Family.
 - Source.
 - Reviewed.
 - Evidence.
 - Tasks.
 - Assets.
 - Open POA&M.
5. If a control has no linked evidence, confirm a Data quality warning appears.
6. API-harness-only step: if an authorized API test harness is available, retrieve the assessmentId from GET /api/cmmc/assessments. The assessment ID is not currently displayed in the UI.

7. API-harness-only step: call GET /api/me/access and confirm the test actor has ManageCmmc before attempting a control-status update.
8. API-harness-only step: update a control status through PATCH /api/cmmc/assessments/{assessmentId}/controls/{controlId} and confirm the assessment completion percentage changes after reloading the UI or calling GET /api/cmmc/assessments/{assessmentId}.
9. API-harness-only step: attempt to mark a control Implemented with Met result but no linked reviewed evidence through the API.
10. Confirm the API rejects the request with a validation error referencing linked evidence.
11. API-harness-only step: attempt to link evidence from another tenant through the same control-status endpoint.
12. Confirm the API rejects the cross-tenant evidence link and does not change the control.

Postman/local development note: local API calls must send the same tenant and development-auth context as the app, including X-Gccs-Dev-Auth, X-Gccs-Tenant, X-Gccs-Dev-Tenant, X-Gccs-Dev-User, X-Gccs-Dev-Email, and X-Gccs-Dev-Role. A 403 means the caller is authenticated but not authorized for the requested tenant or permission.

Expected result: The control baseline is visible in the UI, and the API enforces traceability checks for implemented controls and cross-tenant evidence links.

Reason: CMMC readiness is not just a checklist label. Control status must stay tied to source metadata, evidence traceability, and tenant isolation.

UAT-C03: Create A CMMC POA&M Remediation Item

Category: CMMC readiness module.

Role: Compliance Manager.

Tab: CMMC, then Calendar.

Prerequisite: UAT-C01 is complete and Control readiness has loaded controls.

Steps:

1. Stay on the CMMC tab.
2. Find POA&M remediation.
3. In the POA&M form, enter:
 - Control: AC.L1-3.1.1.
 - Risk: High.
 - Status: Open.
 - Owner: Security.
 - Due date: 2026-07-15.
 - Gap: Synthetic UAT gap: document annual access review evidence.
 - Remediation plan: Upload synthetic access review summary and link it to the control.
4. Click Create POA&M.
5. Confirm the POA&M item appears under POA&M remediation.

6. Confirm the item shows:

- Control AC.L1-3.1.1.
- Risk High.
- Status Open.
- Owner Security.
- Due date 2026-07-15.
- Task: Linked, when displayed.

7. Click the Calendar tab.

8. Set the calendar date range so it includes 2026-07-15.

9. Confirm a CMMC/POA&M-related calendar task appears for the remediation item.

10. If other calendar items appear for contracts or deliverables, ignore them for this CMMC test.

11. Confirm the relevant calendar item shows Module: CMMC.

Expected result: The POA&M item is created, linked to the selected control, and appears as CMMC remediation work on the calendar.

Reason: A readiness workspace must create owner-tracked remediation work, not just display static gaps.

UAT-C04: Generate A CMMC Readiness Report

Category: CMMC readiness module.

Role: Compliance Manager.

Tab: Reports.

Prerequisite: UAT-C01 is complete. UAT-C03 is recommended so the report has POA&M content.

Steps:

1. Click the Reports tab.
2. Find CMMC readiness.
3. In Assessment, choose No-CUI Level 1 readiness workspace or the CMMC assessment created in UAT-C01.
4. Click Generate readiness.
5. Confirm a generated report appears under Recent generated reports.
6. Click the generated CMMC readiness report card to open the report detail panel.
7. Confirm the report detail metric cards include CMMC readiness values:
 - Assessment.
 - Target level.
 - Control rows.
 - Open gaps.
 - Open POA&M.
 - Evidence links.

8. Confirm the section below the metric cards is named `Report content`. Do not expect a literal `Readiness summary` heading in the current UI.
9. Confirm the report wording says it is workflow guidance only and does not claim legal advice, certification decision, assessor determination, contracting-officer determination, government approval, or government endorsement.
10. API-harness-only step: if an authorized API test harness is available, generate the same report through `POST /api/reports/cmmc-readiness?assessmentId={assessmentId}`. Retrieve `assessmentId` from `GET /api/cmmc/assessments`; it is not currently displayed in the UI.
11. Confirm the API creates a tenant-scoped report for an authorized report manager and returns 403 for a user without report-generation permission.
12. Confirm the API rejects a report that would include `Unknown`, `Prohibited`, or real CUI evidence in a No-CUI tenant.

Expected result: A CMMC readiness report is generated as a tenant-scoped workflow artifact and preserves No-CUI/report-language boundaries.

Reason: The CMMC module is incomplete without a report handoff. The report must communicate readiness status without overclaiming certification, legal, assessor, contracting-officer, or government determinations.

UAT-13: Generate Current Report Artifact

Category: A current report artifact.

Role: Compliance Manager.

Tab: `Reports`.

Steps:

1. Click the `Reports` tab.
2. In `Compliance status`, click `Generate status`.
3. Confirm a report appears under `Recent generated reports`, then click its card and confirm the report detail panel opens. Reload the page and confirm the report remains listed.
4. In `Evidence package builder`, enter `Prime review evidence package - No-CUI UAT for Package title`.
5. Select the generated obligation if available.
6. Select contract `DEMO-NC-26-0007`.
7. Select control `AC.L1-3.1.1` if available.
8. Leave `Include draft/rejected evidence when authorized` unchecked.
9. Click `Generate package`.
10. Confirm the package appears under `Recent generated reports` or `Approved evidence packages`, then click its card and confirm the package detail panel opens.
11. In the opened detail panel, confirm the report wording says it is workflow guidance and does not claim legal advice, certification decision, assessor determination, contracting-officer determination, or government endorsement.

Expected result: A current report artifact is generated from tenant-scoped obligations, contract data, and approved evidence metadata.

Reason: Reports are the handoff artifact for internal reviews and prime-review preparation. The acceptance test also verifies that the report avoids certification and legal overclaims.

UAT-14: Verify Audit History For Created Records

Category: Audit history.

Role: Owner, Admin, or Advisor.

Tab: Settings.

Steps:

1. Click the Settings tab.
2. Find Audit log.
3. Set Action to Created.
4. Set Entity to CompanyProfile.
5. Click Filter.
6. Confirm a created event exists for Blue Ridge Federal Support LLC; if the profile existed before this UAT, change Action to Updated and confirm an updated event instead.
7. Set Action back to Created, change Entity to Contract, and click Filter.
8. Confirm a created event exists for DEMO-NC-26-0007 or the created contract ID.
9. Change Entity to ContractDeliverable.
10. Click Filter.
11. Confirm created events exist for Monthly service status report - synthetic and Overdue corrective-action summary - synthetic.
12. Set Action to Updated and click Filter.
13. Confirm an updated event records the Submitted status for Monthly service status report - synthetic.
14. Set Action back to Created, change Entity to ContractClause, and click Filter.
15. Confirm created events exist for attached clauses.
16. Change Entity to EvidenceItem.
17. Click Filter.
18. Confirm a created event exists for MFA configuration summary - synthetic.
19. Change Entity to CmmcAssessment.
20. Click Filter.
21. Confirm a created event exists for No-CUI Level 1 readiness workspace.
22. Change Entity to CmmcPoamItem.
23. Click Filter.
24. Confirm a created event exists for the synthetic CMMC POA&M item.
25. Change Entity to Report.
26. Click Filter.

27. Confirm created events exist for the generated compliance status, evidence package, and CMMC readiness reports.

Expected result: The audit log shows tenant-scoped history for the company profile, contract, deliverable, clause, evidence, CMMC assessment, CMMC POA&M, and report actions.

Reason: Audit history is the accountability trail. It should show who did what, when, and to which tenant-scoped entity.

UAT-15: Verify Audit Access By Role

Category: Audit history.

Role: Auditor, Contributor, Owner.

Tab: Settings.

Steps:

1. As Owner, confirm the Settings tab and Audit log are visible.
2. As Contributor, attempt to access Settings or audit log review.
3. Confirm Contributor cannot view audit logs.
4. As Auditor, attempt to access audit logs.
5. Confirm Auditor cannot access audit logs unless the implementation grants ViewAuditLog.
6. As Advisor, confirm audit visibility is available if assigned the Advisor role.

Expected result: Audit log access follows the role permission matrix.

Reason: Audit logs can expose sensitive operational metadata. Access should be restricted to roles with explicit audit permission.

Acceptance Exit Criteria

The UAT passes only if all of these conditions are true:

1. Tenant mode is NoCui.
2. The synthetic company profile can be saved as a draft, rejects premature completion, and reaches Complete and 100% only after required fields are present.
3. Contributor, Auditor, and Advisor can view but cannot modify the company profile, and cross-tenant profile data is not disclosed.
4. Contract DEMO-NC-26-0007 exists and displays the expected metadata.
5. The synthetic deliverables persist, appear on the calendar, display overdue state correctly, and retain authorized status updates.
6. Contributor and Auditor cannot mutate deliverables, while Advisor behavior matches the current ManageContracts permission, and cross-tenant deliverable data is not disclosed.
7. Published clauses are found and attached with source references.
8. At least one obligation is generated or visible from the attached clause mapping.

9. Obligation status and owner assignment can be updated by an authorized role.
10. Allowed synthetic FCI evidence metadata can be created.
11. CUI classification or upload is blocked in No-CUI mode.
12. A CMMC readiness assessment is created and shows owner, dates, progress, and control-readiness information.
13. CMMC control readiness preserves source metadata and traceability warnings.
14. A CMMC POA&M item is created and appears as CMMC remediation work on the calendar.
15. A current report, evidence package, and CMMC readiness report artifact are generated.
16. Report language avoids certification, legal, compliance, government-approval, and audit-readiness overclaims.
17. Audit history shows the tested profile, contract, deliverable, clause, evidence, CMMC, and report events.
18. Unauthorized roles cannot mutate restricted workflow records.

Hidden Risks, Edge Cases, And Dependencies

Item	Risk
Local development auth	Role switching may require API header changes or manual test setup; the default UI does not present a production sign-in flow.
Existing profile data	A tenant has one current company profile. Run these steps in a dedicated UAT tenant so the synthetic profile does not overwrite customer metadata.
Profile completion	100% reflects presence of the implemented profile fields. It is not verification of SAM registration, SBA size status, eligibility, certification, or legal compliance.
SAM.gov lookup	Profile completion does not require the optional SAM.gov lookup. Provider availability and lookup correctness are outside this focused UAT unless separately tested.
Static test dates	The supplied dates support this fixed fixture. Update contract, deliverable, and calendar date ranges together if the UAT is executed after the fixture period.
Deliverable cleanup	The current API exposes list, create, and update operations but no deliverable deletion operation. Use a disposable UAT tenant or retain synthetic records as test evidence.
Audit failure atomicity	Focused tests prove successful profile and deliverable audit creation, but do not prove rollback under an injected audit-writer failure. Do not claim mutation-and-audit atomicity without that additional test.
Clause IDs	Clause search returns implementation-specific IDs; testers should copy the actual published IDs from the current environment.
Obligation generation timing	Some obligations may generate automatically on clause attachment; others may require an explicit generate action.
Evidence linking	Evidence can be accepted without an obligation link if the obligation ID is not visible; this reduces report package completeness.
CMMC readiness scope	CMMC module results are readiness workflow records only. They do not prove CMMC certification, assessment success, legal compliance, or authorization to store real CUI.
CMMC controls	Available controls depend on the seeded control library and selected assessment level. A Level 1 assessment will not show every Level 2 control.
CMMC POA&M dates	The fixed POA&M due date is intentionally synthetic. If the date is in the past when UAT runs, the item may display Over due; that is acceptable for this fixture.
Report scope	Evidence packages include only evidence matching selected scope and status rules. Draft/rejected evidence requires authorization.
Audit filters	Audit records may be easier to find by Entity than by exact actor when local development uses generated user IDs.
No-CUI enforcement	Do not use real CUI to test blocking. Use synthetic classification labels and allowed synthetic text only.

Item	Risk
Customer-facing claims	This UAT proves workflow behavior only. It does not prove CMMC certification, legal compliance, government approval, or production CUI readiness.